Cyber Crime Unit
Delhi Police
Intelligence Fusion
& Strategic
Operations

INTELLIGENCE FUSION AND STRATEGIC OPERATIONS



BUSINESS EMAIL COMPROMISE

This kind of fraud depends on use of a real email address that is deceptively similar to one that would be used by the target company or its legitimate suppliers to trigger a kind of “fictitious payee” scam. The target company is tricked into sending funds by wire transfer to a bank account which is under the fraudsters’ control. This bank account is often in Hong Kong, UK, China and the timeframe for intercepting and recovering funds that have been stolen in this way is very short.

Three Basic Elements to the scam

1. Fraudsters secure an internet domain name that is visually very similar to the domain name of the target company or of the target’s real suppliers. For instance, if the target company is named AABBCC, Ltd. and its domain is www.AABBCC.com, the fraudsters will secure registration of www.AAABBCC.com.

2.Scammers will research publicly available information about the target company looking for the names of senior financial officers and employees, especially chief financial officers and comptrollers.

3. Fraudsters will use what hackers call “social engineering” to secure the name and legitimate email address of a target company employee who is responsible for making large wire transfers.

With that last piece of information, the fraudsters have two vital parts of the scam: the name and email address of a person who is authorized to initiate wire-transfers, and the format of legitimate company email addresses. If the name of the person with wire transfer authority is Mr. Bhatia and his email address in our example is abhatia[at]aabbcc[dot]com, and they learn from the company’s website that the CFO’s name is Mr. Ram Raghav, they will know that the CFO’s legitimate email address will very likely be Rraghav[at]aabbcc[dot]com. Putting all these pieces together can take experienced fraudsters just a few hours of work.

The next step in the scam is sending an email that purports to be from the company’s CFO to the person authorized to send wire transfer instructions, but using the deceptive domain name. In this example, the “From” line of the email will appear as

“From: Ram Raghav .” Notice the extra ‘a’ in this email address? Unless you were forewarned, you’d be very likely not to notice it. Instead, when Mr. Bhatia receives an email from rraghav[at]aaabbcc[dot]com telling him to immediately send a wire transfer to a particular bank account (accompanied by a plausible explanation for why the funds should be transferred, often with legitimate-looking invoices attached), he may well do it.

Another variation:

A variation on this pattern is the use of a domain name deceptively similar to one of the target company’s regular suppliers. In this kind of case, the fraudsters need to know the identity of who is selling to the target company, something that may require some inside information. Instead of impersonating a company officer with authority to order wire transfers, the fraudsters impersonate the company’s supplier. Although the information required to put this scheme in play is harder to come by, once it is obtained, the fraudsters have a better chance of success, since the funds only need to be redirected to a bank account under the fraudsters control, but all other information fits the target company’s usual course of paying invoices submitted by a known supplier. Information about a supplier can be gained by searching websites of companies likely to be selling to the target company, which may list the supplier’s large customers, or through social engineering, e.g. by getting to know someone in the supplier’s sales force and waiting for the identity of the supplier’s large customers to be disclosed.

Preventive Measures/Precautions

1. Avoid free web-based e-mail accounts: Establish a company domain name and use it to establish company e-mail accounts in lieu of free, web-based accounts.

2. Be careful what is posted to social media and company websites, especially job duties/descriptions, hierarchal information, and out of office details.

3. Be suspicious of requests for secrecy or pressure to take action quickly.

4. Consider additional IT and financial security procedures, including the implementation of a 2-step verification process. For example -

o Out of Band Communication: Establish other communication channels, such as telephone calls, to verify significant transactions. Arrange this second-factor authentication early in the relationship and outside the e-mail environment to avoid interception by a hacker.

o Digital Signatures: Both entities on each side of a transaction should utilize digital signatures. This will not work with web-based e-mail accounts. Additionally, some countries ban or limit the use of encryption.

o Delete Spam: Immediately report and delete unsolicited e-mail (spam) from unknown parties. DO NOT open spam e-mail, click on links in the e-mail, or open attachments. These often contain malware that will give subjects access to your computer system.

o Forward vs. Reply: Do not use the “Reply” option to respond to any business e-mails. Instead, use the “Forward” option and either type in the correct e-mail address or select it from the e-mail address book to ensure the intended recipient’s correct e-mail address is used.

5. Consider implementing Two Factor Authentication (TFA) for corporate e-mail accounts. TFA mitigates the threat of a subject gaining access to an employee’s e-mail account through a compromised password by requiring two pieces of information to login: something you know (a password) and something you have (such as a dynamic PIN or code).

6. Significant Changes: Beware of sudden changes in business practices. For example, if a current business contact suddenly asks to be contacted via their personal e-mail address when all previous official correspondence has been through company e-mail, the request could be fraudulent. Always verify via other channels that you are still communicating with your legitimate business partner.

7. Create intrusion detection system rules that flag e-mails with extensions that are similar to company e-mail. For example, legitimate e-mail of abc_company.com would flag fraudulent e-mail of abc-company.com.

8. Register all company domains that are slightly different than the actual company domain.

9. Verify changes in vendor payment location by adding additional two-factor authentication such as having a secondary sign-off by company personnel.

10. Confirm requests for transfers of funds. When using phone verification as part of the two-factor authentication, use previously known numbers, not the numbers provided in the e-mail request.

11. Know the habits of your customers, including the details of, reasons behind, and amount of payments.

12. Carefully scrutinize all e-mail requests for transfers of funds to determine if the requests are out of the ordinary.

Advise for victims

1. If funds are transferred to a fraudulent account, it is important to act quickly

2. Contact your financial institution immediately upon discovering the fraudulent transfer

3. Request that your financial institution contact the corresponding financial institution where the fraudulent transfer was sent

4. Contact your Police Station if the fund transfer is recent. The Police, working in coordination with the banks, might be able to help return or freeze the funds

5. File a complaint, regardless of money loss, at your local police station or District Cyber Cell.

How to make a complaint:

When contacting law enforcement or filing a complaint with the Police Station, it is important to provide a brief description of the incident, and consider providing the following financial information:

1. Originating Name

2. Originating Location

3. Originating Bank Name

4. Originating Bank Account Number

5. Recipient Name

6. Recipient Bank Name

7. Recipient Bank Account Number

8. Recipient Bank Location (if available)

9. Intermediary Bank Name (if available)

10. SWIFT Number

11. Date

12. Amount of Transaction

13. Additional Information (if available) - including “FFC”- For Further Credit; “FAV” – In Favor Of

Main Link

Home
Cyber Crimes
Contact Us
Report a Cyber Crime
Cyber Safety
Photo Gallery

---------Cyber Crimes---------

Email Frauds
Social Media crimes
Mobile App related crimes
Business Email Compromise
Data Theft
Ransomeware
Net Banking/ATM Frauds
Fake Calls Frauds
Insurance Frauds
Lottery Scam
Bitcoin
Cheating Scams
Online Transactions Frauds
Gift Card Frauds
FaceBook Friendship Frauds
FaceBook SOS Frauds
Fake Shopping Site Frauds
Fake Government Website Frauds
Herbal Oil Frauds
Job Frauds through Call Centres
OLX QR Code Frauds
KBC Lottery Frauds
PayTM KYC Frauds
Sextortion Frauds
Phishing-Vishing Frauds

Connect With Us